

# Auth & Session Security Analyzer

## Rapport d'audit de securite Android

Application analysee : app-debug  
Type d'authentification : SESSION\_COOKIE  
Vulnerabilites detectees : 87  
Date d'analyse : 17/05/2026 16:12

**Score global de securite : 0 / 10 (CRITIQUE)**



|       |                               |                    |                                 |
|-------|-------------------------------|--------------------|---------------------------------|
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | Action.java        | http://s                        |
| MOYEN | Communication en clair (HTTP) | zzm.java           | http://p                        |
| ELEVE | Hachage MD5 faible            | zzak.java          | MessageDigest.getInstance("MD5" |
| ELEVE | Hachage MD5 faible            | zzbl.java          | MessageDigest.getInstance("MD5" |
| MOYEN | Communication en clair (HTTP) | zzgk.java          | http://w                        |
| ELEVE | Hachage MD5 faible            | zzhl.java          | MessageDigest.getInstance("MD5" |
| MOYEN | Communication en clair (HTTP) | PlusOneButton.java | http://s                        |
| MOYEN | Communication en clair (HTTP) | PlusOneButton.java | http://s                        |
| MOYEN | Communication en clair (HTTP) | zzax.java          | http://h                        |

### 3. Analyse Dynamique - Tests d'authentification

L'analyse dynamique evalue le comportement de l'application en cours d'exécution. Les tests portent sur la validité des tokens après déconnexion, la durée de vie, la rotation des tokens, la fixation de session et la robustesse du mécanisme d'authentification.

|                               |                                   |
|-------------------------------|-----------------------------------|
| Mode d'analyse :              | API_DIRECT                        |
| Déconnexion effective :       | Non (VULNERABLE - rejeu possible) |
| Durée de vie du token :       | None min                          |
| Rotation des refresh tokens : | Non teste                         |

#### Vulnérabilités détectées lors des tests :

|          |                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------|
| CRITIQUE | POST http://localhost:8888/login envoie username+password sans chiffrement - interceptable pa   |
| ELEVE    | InsecureBankv2 n'émet aucun token/cookie de session. Les credentials sont retransmis à chaque r |
| ELEVE    | 10 tentatives de login échouées consécutives acceptées sans blocage ni CAPTCHA                  |
| MOYEN    | L'application n'a pas de mécanisme de logout côté serveur. Le menu 'Restart' ne fait que navigu |
| ELEVE    |                                                                                                 |

#### 4. Cookie Security Scanner (OWASP)

Analyse des headers HTTP Set-Cookie interceptes via mitmproxy. Verification des 7 controles OWASP : flag HttpOnly (MASVS-NETWORK-2), flag Secure (MASVS-NETWORK-1), attribut SameSite (protection CSRF), Max-Age/Expires, restriction de domaine et prefixes \_\_Host-/ \_\_Secure-.

Cookies interceptes : 0 | Findings : 0 | Score : 10.0/10

Aucun cookie intercepte. Verifier que le proxy mitmproxy est actif lors de l'analyse dynamique.

#### 5. Android Storage Scanner (SharedPreferences / Keystore)

Audit du stockage des donnees sensibles dans le code source decompile. Verification de l'usage de Android Keystore, EncryptedSharedPreferences, et detection des tokens stockes en clair (MASVS-STORAGE-1 et STORAGE-2).

Findings : 38 | Score : 0/10 | EncryptedSharedPreferences : NON | Android Keystore : NON

|  |     |
|--|-----|
|  | NON |
|  | NON |

| Severite | Type                            | Fichier                  | Fix recommande                                                          |
|----------|---------------------------------|--------------------------|-------------------------------------------------------------------------|
| ELEVE    | Données sensibles dans les logs | FragmentManagerImpl...   | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | FragmentManagerImpl...   | Supprimer tout Log contenant des données d'auth en production (Build... |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompat.java       | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompatFroyo.j...  | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompatFroyo.j...  | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompatKitKat.j... | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ContextCompatKitKat.j... | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | FileProvider.java        | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | EnvironmentCompat.java   | Utiliser uniquement le stockage interne (getFilesDir).                  |
| ELEVE    | Données sensibles dans les logs | SpinnerCompat.java       | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | SpinnerCompat.java       | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | SpinnerCompat.java       | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | SpinnerCompat.java       | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | RegisteredMediaRoute...  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | RemotePlaybackClient...  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | RemotePlaybackClient...  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | RemotePlaybackClient...  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | RemotePlaybackClient...  | Supprimer tout Log contenant des données d'auth en production (Build... |

|          |                                 |                           |                                                                         |
|----------|---------------------------------|---------------------------|-------------------------------------------------------------------------|
| ELEVE    | Données sensibles dans les logs | DoLogin.java              | Supprimer tout Log contenant des données d'auth en production (Build... |
| CRITIQUE | Écriture sur stockage externe   | DoTransfer.java           | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | DoTransfer.java           | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ViewStatement.java        | Utiliser uniquement le stockage interne (getFilesDir).                  |
| CRITIQUE | Écriture sur stockage externe   | ViewStatement.java        | Utiliser uniquement le stockage interne (getFilesDir).                  |
| ELEVE    | Données sensibles dans les logs | AppInviteReferral.java    | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | AppInviteReferral.java    | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | zzm.java                  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | zzn.java                  | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | GcmNetworkManager.j...    | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | GoogleCloudMessagin...    | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | InstanceIDListenerServ... | Supprimer tout Log contenant des données d'auth en production (Build... |
| ELEVE    | Données sensibles dans les logs | zzc.java                  | Supprimer tout Log contenant des données d'auth en production (Build... |
| CRITIQUE | Écriture sur stockage externe   | zzcb.java                 | Utiliser uniquement le stockage interne (getFilesDir).                  |
| ELEVE    | Absence d'Android Keystore      | - (non détecté dans le... | Supprimer tout Log contenant des données d'auth en production (Build... |

## 6. Session Security Scanner (Entropie / Fixation / Timeout)

Tests de securite de session cote serveur : analyse de l'entropie du Session ID (MASVS-AUTH-1), test de fixation de session (MASVS-AUTH-3), timeout d'inactivite (MASVS-AUTH-2), et invalidation post-deconnexion.

Mode : SESSION\_SCANNER | Session ID : Non detecte | Findings : 2

| Severite | Probleme                 | MASVS        | Correction                                                     |
|----------|--------------------------|--------------|----------------------------------------------------------------|
| CRITIQUE | Aucun Session ID détecté | MASVS-AUTH-1 | Le serveur n'émet pas de cookie de session identifiable.       |
| INFO     | Test logout ignoré       |              | Login échoué - backend inaccessible ou credentials incorrects. |

## 7. Scores MASVS par Domaine

Les scores reflètent le niveau de securite par domaine OWASP MASVS v2. Chaque vulnerabilite deduit des points selon sa severite. Un score inferieur a 4 indique un risque critique sur ce domaine.

|                  |             |       |
|------------------|-------------|-------|
| MASVS-AUTH       | <div></div> | 10/10 |
| MASVS-STORAGE    | <div></div> | 10/10 |
| MASVS-CRYPTO     | <div></div> | 10/10 |
| MASVS-NETWORK    | <div></div> | 10/10 |
| Cookie Security  | <div></div> | 10/10 |
| Storage Security | <div></div> | 0/10  |

## 8. Checklist de Securite (MASVS)

Checklist generee par IA (Claude) adaptee au type d'authentification detecte. Chaque controle est mappe a un chapitre OWASP MASVS pertinent. Ces points constituent le referentiel de verification pour la revue de code.

# ? Checklist de Sécurité OAuth2 - Android Native (Authorization Code + PKCE)

- > \*\*Application analysée :\*\* Android native OAuth2 client
- > \*\*Référentiel :\*\* OWASP MASVS v2 + RFC 6749 / RFC 7636 / RFC 9700
- > \*\*Date de génération :\*\* 2025
- > \*\*Findings statiques intégrés :\*\* 10 findings pré-analysés

---

## ? Résumé Exécutif

| Sévérité   | Nombre d'items | Findings statiques confirmés            |
|------------|----------------|-----------------------------------------|
| -----      | -----          | -----                                   |
| ? CRITICAL | 5              | 2 (HARDCODED_SECRET)                    |
| ? HIGH     | 7              | 1 (LOG_CREDENTIALS) + 1 (WEAK_HASH_MD5) |
| ? MEDIUM   | 5              | 6 (HTTP_CLEARTEXT)                      |
| ? LOW      | 3              | -                                       |
| **TOTAL**  | **20**         | **10**                                  |

---

### ## ? SECTION 1 - PKCE (Proof Key for Code Exchange)

---

- [MASVS-NETWORK-1] PKCE activé sur chaque requête d'autorisation OAuth2 :  
vérifier la présence des paramètres `code\_challenge` et  
`code\_challenge\_method=S256` dans l'URL d'autorisation.  
La méthode `plain` est INTERDITE (triviale à intercepter).  
| Sévérité: CRITICAL | CWE: CWE-345 (Insufficient Verification of Data Authenticity)
  
  - [MASVS-NETWORK-1] Le `code\_verifier` est généré avec une entropie suffisante :  
longueur entre 43 et 128 caractères, tiré de SecureRandom (pas de Math.random(),  
pas de UUID déterministe). Valider via décompilation de la méthode de génération.  
| Sévérité: CRITICAL | CWE: CWE-330 (Use of Insufficiently Random Values)
  
  - [MASVS-NETWORK-1] Le `code\_verifier` n'est JAMAIS persisté sur disque ni logué :  
il doit rester en mémoire uniquement le temps du flow, puis être détruit.  
| Sévérité: HIGH | CWE: CWE-312 (Cleartext Storage of Sensitive Information)
- 

> **Contexte findings statiques :** Le finding `WEAK\_HASH\_MD5`  
> (`com/google/android/gms/ads/.../zza.java:116`) signale l'usage de MD5.  
> **Si MD5 est utilisé pour calculer le `code\_challenge` PKCE, c'est CRITIQUE :**  
> RFC 7636 impose SHA-256. À vérifier que ce code n'est pas dans le chemin PKCE.

---

### ## ? SECTION 2 - State Parameter (CSRF Protection)

---

- [MASVS-NETWORK-1] Le paramètre `state` est présent dans chaque requête  
d'autorisation et vérifié à la réception du callback. Toute réponse dont  
le `state` ne correspond pas à la valeur générée localement doit être rejetée.  
| Sévérité: CRITICAL | CWE: CWE-352 (Cross-Site Request Forgery)

- [MASVS-NETWORK-1] Le `state` est cryptographiquement aléatoire (? 128 bits, SecureRandom), unique par session, et invalidé après usage unique.

Un `state` fixe ou prévisible annule entièrement la protection CSRF.

| Sévérité: HIGH | CWE: CWE-330 (Use of Insufficiently Random Values)

...

---

### ## ? SECTION 3 - Validation de la redirect\_uri

...

- [MASVS-NETWORK-1] La `redirect\_uri` est validée côté serveur par correspondance EXACTE (pas de préfixe, pas de wildcard, pas de regex permissive).

Tester : injection de `redirect\_uri=https://attacker.com` ? le serveur doit retourner une erreur `invalid\_request`.

| Sévérité: CRITICAL | CWE: CWE-601 (Open Redirect)

- [MASVS-PLATFORM-1] Le schéma de la `redirect\_uri` Android utilise soit un App Link HTTPS vérifié (Digital Asset Links), soit un custom scheme UNIQUE et non-devinable (ex: `com.myapp.oauth://callback`).

Les schémas génériques comme `myapp://` sans vérification sont exploitables par d'autres apps malveillantes.

| Sévérité: HIGH | CWE: CWE-939 (Improper Authorization in Handler for Custom URL Scheme)

...

---

### ## ? SECTION 4 - Scope Minimal

...

- [MASVS-AUTH-1] Les scopes OAuth2 demandés sont strictement limités aux besoins fonctionnels de l'application. Aucun scope administratif, `offline\_access` non justifié, ou scope de type wildcard (`\*`, `all`) ne doit être présent.

Inspecter les appels réseau et la configuration OAuth dans l'APK.

| Sévérité: HIGH | CWE: CWE-272 (Least Privilege Violation)

- [MASVS-AUTH-1] En cas d'évolution des besoins, une nouvelle demande de consentement est déclenchée plutôt qu'un scope élargi silencieux.

Le refresh token ne doit pas permettre d'

## 9. Criteres d'Acceptation de Securite

*Les criteres d'acceptation definissent les conditions que le systeme doit satisfaire pour etre considere comme securise. Ils servent de base aux tests d'acceptation, aux revues de code et aux audits de conformite MASVS.*

### --- Criteres Gherkin (bases sur les tests echoues) ---

3. Given a user has an unauthenticated session with an initial session cookie
4. When the user submits valid login credentials
5. Then a new session cookie must be generated and differ from the pre-login session cookie
6. Given a user has an unauthenticated session with an initial session cookie
7. When the user successfully authenticates
8. Then the previous session cookie must be invalidated by the server
9. Given an attacker has captured a session cookie before authentication
10. When the legitimate user logs in with valid credentials
11. Then the captured session cookie must no longer be accepted by the server
12. Given a user completes the login process successfully
13. When the server responds to the authentication request
14. Then the Set-Cookie header must contain a newly generated session identifier
15. Given multiple login attempts are made with the same initial session cookie
16. When each authentication succeeds
17. Then each resulting session cookie must be unique and not reuse any prior session identifier